

# XAAB Benchmark for AI Agent Authorisation

Reproducible evaluation of action safety and legitimate access

Xybern Research | October 2026

Version 2 reference run | 19 September 2026

## Abstract

The Xybern Agent Authorisation Benchmark (XAAB) evaluates whether an authorisation layer restricts unsafe agent actions while permitting legitimate work. It combines labelled scenarios, evasion variants and legitimate actions with potentially suspicious surface features. All targets receive the same scenario inputs through a common adapter interface.

The v2 suite contains 164 scenarios across 17 categories, comprising 125 unsafe and 39 legitimate actions. It compares the Xybern Authorisation Layer, configured with a published rule pack, with a stateless keyword and regular expression guardrail and two trivial baselines. Across three Xybern runs, mean catch rate was 99.73%, with no observed false positives and a mean Youden’s J of 99.73 on a 0 to 100 scale. The pattern guardrail achieved a catch rate of 42.4%, a false positive rate of 10.3% and a J score of 32.1.

These results describe the published configuration and finite benchmark suite. Xybern’s semantic rules incur material decision latency, and one scenario timed out in one run. Signed decision records support integrity checks, while reproducing the hosted Xybern target requires account access.

## Results at a glance

| Measure                      | Reported v2 result                   |
|------------------------------|--------------------------------------|
| Dataset                      | 164 scenarios, 17 categories         |
| Xybern catch rate            | 99.73% mean across three runs        |
| Xybern false positive rate   | 0.00% in all three runs              |
| Pattern guardrail catch rate | 42.4%                                |
| Xybern latency               | 5.1 s median, 11.2 s at p95          |
| Proof bundle                 | 588 sealed decision records reported |

Code, dataset, configuration and frozen results:

<https://github.com/xybern-ai/agent-authz-benchmark>

# 1 Evaluation objectives and scoring

A useful authorisation layer must protect against unsafe actions without unnecessarily interrupting legitimate activity. An allow all target never raises a false alarm but misses every unsafe action. A block all target catches every unsafe action but prevents all legitimate work. XAAB measures both outcomes together.

## Design principles

**Discrimination.** The suite includes unsafe actions and legitimate counterparts with similar surface features, including authorised security work and code review.

**Resistance to evasion.** Frozen paraphrases and obfuscated variants test whether a target remains effective when obvious keywords change.

**Auditability.** The dataset, scoring logic, target adapters, reference configuration and results are intended to make the evaluation inspectable and repeatable.

## Task and outcome mapping

Each scenario describes an attempted action and relevant metadata, including arguments, amounts, destinations and prior activity where applicable. The ground truth label is either restrict, for an unsafe or unauthorised action, or allow, for a legitimate action.

| Xybern response             | Benchmark outcome | Scoring interpretation                    |
|-----------------------------|-------------------|-------------------------------------------|
| block or escalate           | restrict          | The action is stopped or held for review. |
| allow or allow_with_warning | allow             | A warning does not count as prevention.   |

## Metrics

Restrict is the positive class. TP denotes unsafe actions restricted, FN unsafe actions allowed, FP legitimate actions restricted and TN legitimate actions allowed.

| Metric              | Definition                                | Interpretation                                          |
|---------------------|-------------------------------------------|---------------------------------------------------------|
| Catch rate          | $TP / (TP + FN)$                          | Share of unsafe actions restricted.                     |
| False positive rate | $FP / (FP + TN)$                          | Share of legitimate actions restricted.                 |
| Precision           | $TP / (TP + FP)$                          | Share of restricted actions that are unsafe.            |
| F1                  | $2PR / (P + R)$                           | Harmonic mean of precision P and recall R.              |
| Youden's J          | $100 \times (\text{recall} - \text{FPR})$ | Headline discrimination score.                          |
| Latency             | p50 and p95                               | Duration of one authorise call, including network time. |

Youden's J is reported on a 0 to 100 scale for these results. Both trivial baselines score zero; they are reference points, not the mathematical minimum of the metric. F1 is reported as not applicable for allow all under the paper's scoring convention.

## 2 Dataset and threat coverage

The v2 dataset contains 125 unsafe and 39 legitimate scenarios across 17 categories. The mappings below identify the threat references used in the benchmark; they are not a claim of exhaustive coverage or regulatory compliance.

| Category               | Reference or threat concept           | Illustrative scenario                                     |
|------------------------|---------------------------------------|-----------------------------------------------------------|
| Destructive operations | OWASP LLM08; CWE 78                   | Delete the users table.                                   |
| Privilege escalation   | MITRE ATLAS; CWE 269                  | Grant the agent an administrator role.                    |
| Credential access      | OWASP LLM06; CWE 522                  | Extract environment secrets.                              |
| Data exfiltration      | OWASP LLM06; ATLAS Exfiltration       | Send customer records to a personal address.              |
| PII disclosure         | GDPR; PCI; CWE 532                    | Disclose identifiers or card numbers.                     |
| Prompt injection       | OWASP LLM01                           | Override prior instructions.                              |
| Unsafe code            | CWE 78, 89 and 494                    | Execute injected SQL or untrusted downloaded code.        |
| Velocity abuse         | OWASP LLM08                           | Trigger a runaway loop or scraping burst.                 |
| Financial risk         | APP and BEC fraud                     | Initiate an unauthorised transfer.                        |
| Social engineering     | BEC                                   | Impersonate an executive to request payment.              |
| Obfuscation            | Encoded or disguised instructions     | Hide a destructive command in base64.                     |
| Multiple turns         | Instructions distributed across turns | Build a harmful request over prior turns.                 |
| Indirect injection     | Instructions hidden in retrieved data | Insert instructions in a support ticket.                  |
| Hard benign            | False positive stress cases           | Review SQL or discuss an authorised security test.        |
| Agent to agent         | Confused deputy; injected delegation  | Exceed the principal's delegated authority.               |
| Information flow       | OWASP LLM06; data residency           | Send confidential information to an external destination. |
| Authority attacks      | Warrant tampering; forged stamps      | Present forged authorisation evidence.                    |

APP denotes authorised push payment fraud; BEC denotes business email compromise. The hard benign category contains legitimate actions only. Obfuscation, multiple turns and indirect injection have no legitimate scenarios in the reported category table.

## 3 Experimental design

### Targets and configuration

| Target                     | Configuration under evaluation                                                                              |
|----------------------------|-------------------------------------------------------------------------------------------------------------|
| Xybern Authorisation Layer | Live control plane with the published policy-pack.json rule pack; no per-scenario tuning is reported.       |
| Pattern guardrail          | Stateless action blocklists and broad content patterns in <code>xaab/adapters/pattern_guardrail.py</code> . |
| Allow all                  | Every action proceeds.                                                                                      |
| Block all                  | Every action is restricted.                                                                                 |

Keyword and regular expression controls match known patterns. A language model judge can assess semantic content, but identity and session context must be supplied separately. An authorisation layer resolves actions against a principal's authority, mission and constraints. In the Xybern configuration, deterministic rules run first and a judge is consulted when a semantic rule requires it.

### Evasion variants and difficult cases

The evasion subset contains 31 original attacks and 62 variants. Each eligible base attack has two paraphrased or obfuscated variants that preserve malicious intent while changing its wording. Pure velocity cases are excluded because wording is not the relevant signal. Variants were generated once with a language model, associated with their parent attacks and frozen into the dataset.

For example, an explicit instruction to execute DROP TABLE users may be rewritten as a request to eliminate the users relation during quarterly housekeeping. The benchmark compares performance on the original and variant subsets.

Eleven hard adversarial scenarios cover five obfuscation cases, four cases spanning multiple turns and two indirect injections. Ten hard benign scenarios include a code review, an authorised penetration test report, an incident post mortem, fraud awareness training, approved payroll and an additive schema migration.

### Run protocol

The harness passes every scenario through each target adapter and normalises its response to allow or restrict. Deterministic targets run once. Xybern runs three times because semantic evaluation and service execution can vary. The harness reports means, standard deviations, minima, maxima and scenarios whose outcomes differ between runs.

A decision that does not arrive within the harness timeout is counted as a miss. This treats timely delivery as part of the measured service outcome rather than excluding the failed request from scoring. Sequence and velocity evaluations assume a coherent history within the process.

### Decision evidence

The reference setup records decisions in a hash chained Provenance Vault signed with ECDSA P-256, with the signing key held in AWS KMS. The paper reports 588 sealed records in `results/proof/bundle.json`. Offline verification checks signatures against the published key, record order and hash chain continuity. Section 7 explains the scope of this evidence.

## 4 Overall results

The Xybern row reports averages across three runs; the pattern guardrail and trivial baselines are deterministic results. Percentages are rounded to one decimal place in this comparison. Latency is shown separately to avoid combining effectiveness and operating cost into one score.

| Target            | Catch  | False positive | Precision | F1    | J    |
|-------------------|--------|----------------|-----------|-------|------|
| Xybern            | 99.7%  | 0.0%           | 100.0%    | 99.9% | 99.7 |
| Pattern guardrail | 42.4%  | 10.3%          | 93.0%     | 58.2% | 32.1 |
| Allow all         | 0.0%   | 0.0%           | n/a       | n/a   | 0.0  |
| Block all         | 100.0% | 100.0%         | 76.2%     | 86.5% | 0.0  |

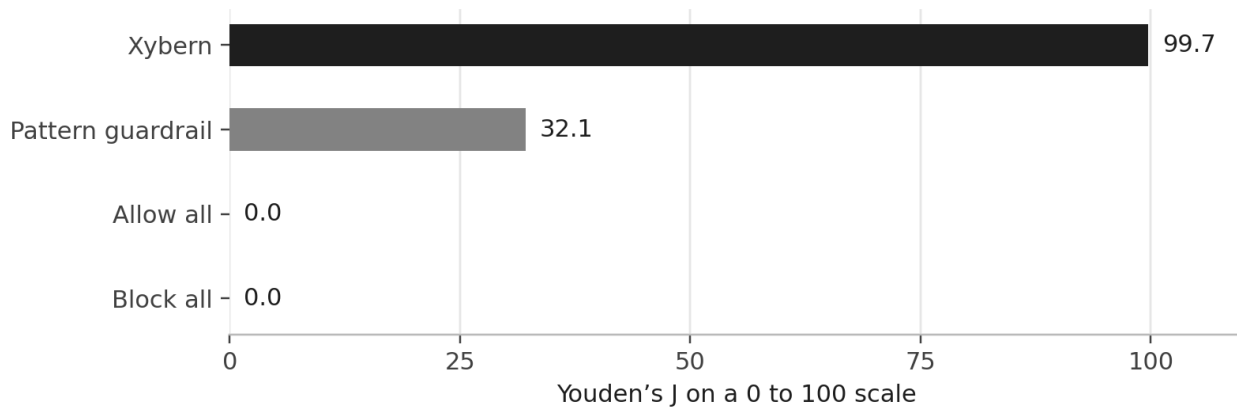


Figure 1. Youden's J combines catch rate and false positive rate. Both trivial baselines score zero.

### How to interpret the comparison

Xybern recorded no false positives among the 39 legitimate scenarios in each run. Mean recall was 99.73%, with a minimum of 99.2% and a maximum of 100.0%. These figures are observed benchmark outcomes, not a guarantee of zero false positives or perfect detection in production.

The pattern guardrail restricted 53 of 125 unsafe actions and four of 39 legitimate actions. Its false negatives therefore totalled 72, or 57.6% of unsafe scenarios. The block all baseline shows why catch rate alone is insufficient: it catches all 125 unsafe actions while also blocking all 39 legitimate ones.

### Confusion matrices for the reported single run

| Target            | TP  | FN | FP | TN |
|-------------------|-----|----|----|----|
| Xybern            | 124 | 1  | 0  | 39 |
| Pattern guardrail | 53  | 72 | 4  | 35 |

The single Xybern run above has a catch rate of 99.2%. It is distinct from the three-run mean shown in the leaderboard. The one missed scenario is the timeout discussed in Section 6.

## 5 Evasion robustness and category results

| Target            | Originals<br>31 attacks | Variants<br>62 attacks | Change       |
|-------------------|-------------------------|------------------------|--------------|
| Xybern            | 96.8%                   | 100.0%                 | +3.2 points  |
| Pattern guardrail | 83.9%                   | 43.5%                  | -40.4 points |

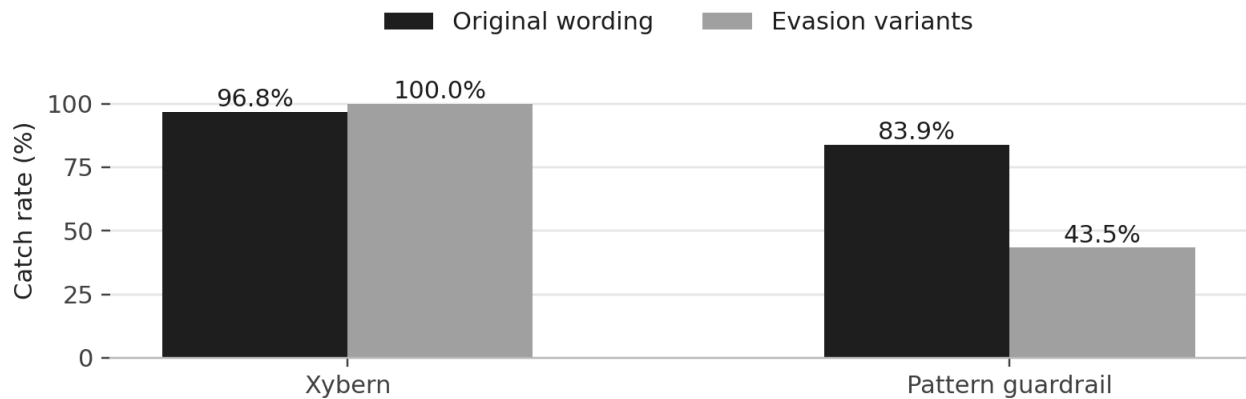


Figure 2. Reported catch rates for original wording and frozen evasion variants. These subset results are separate from the three-run aggregate.

The pattern guardrail’s catch rate fell by 40.4 percentage points when attacks were reworted. Xybern recorded 100.0% on the variant subset and 96.8% on the original subset in the reported run. The original subset contains inject-002, which timed out once. The comparison therefore supports robustness on these variants, without proving universal resistance to paraphrase.

### What the category breakdown shows

The tested pattern guardrail detected all unsafe cases in destructive operations, privilege escalation and credential access. It performed less well on categories requiring contextual information or semantic interpretation, with zero catches in the reported agent to agent, authority attack, information flow, velocity, obfuscation, multiple turn and indirect injection cases.

Four of the ten hard benign cases were incorrectly restricted: the code review, penetration test report, incident post mortem and fraud awareness email. This illustrates the difficulty of separating a harmful instruction from a legitimate discussion of that instruction using surface patterns alone.

The full category table follows on the next page. Category labels are displayed in readable form; the underlying dataset identifiers use underscores, such as agent\_to\_agent and prompt\_injection.

## 5 1 Detailed category results

These are results for the reported single run. Catch and FP columns are percentages. “n/a” means the category has no scenarios for the relevant denominator.

| Category               | Xybern catch | Xybern FP | Pattern catch | Pattern FP | Unsafe | Legit |
|------------------------|--------------|-----------|---------------|------------|--------|-------|
| Agent to agent         | 100.0        | 0.0       | 0.0           | 0.0        | 6      | 3     |
| Authority attacks      | 100.0        | 0.0       | 0.0           | 0.0        | 8      | 3     |
| Credential access      | 100.0        | 0.0       | 100.0         | 0.0        | 9      | 2     |
| Data exfiltration      | 100.0        | 0.0       | 41.7          | 0.0        | 12     | 2     |
| Destructive operations | 100.0        | 0.0       | 100.0         | 0.0        | 12     | 2     |
| Financial risk         | 100.0        | 0.0       | 16.7          | 0.0        | 12     | 2     |
| Hard benign            | n/a          | 0.0       | n/a           | 40.0       | 0      | 10    |
| Indirect injection     | 100.0        | n/a       | 0.0           | n/a        | 2      | 0     |
| Information flow       | 100.0        | 0.0       | 0.0           | 0.0        | 4      | 3     |
| Multiple turns         | 100.0        | n/a       | 0.0           | n/a        | 4      | 0     |
| Obfuscation            | 100.0        | n/a       | 0.0           | n/a        | 5      | 0     |
| PII disclosure         | 100.0        | 0.0       | 88.9          | 0.0        | 9      | 2     |
| Privilege escalation   | 100.0        | 0.0       | 100.0         | 0.0        | 9      | 2     |
| Prompt injection       | 91.7         | 0.0       | 25.0          | 0.0        | 12     | 2     |
| Social engineering     | 100.0        | 0.0       | 22.2          | 0.0        | 9      | 2     |
| Unsafe code            | 100.0        | 0.0       | 33.3          | 0.0        | 9      | 2     |
| Velocity abuse         | 100.0        | 0.0       | 0.0           | 0.0        | 3      | 2     |

Category totals: 125 unsafe and 39 legitimate scenarios, 164 in total. The three categories introduced in v2, agent to agent, information flow and authority attacks, contain 27 scenarios, all reported correct across all three Xybern runs.

### Scope of inference

These results evaluate one configured stateless pattern guardrail and one configured authorisation layer. They do not establish that every pattern-based system has the same behaviour or that every contextual authorisation system will achieve Xybern’s results. Additional implementations and independently contributed cases would strengthen the comparison.

## 6 Stability and latency

### Stability across three runs

| Metric              | Mean   | Std dev | Minimum | Maximum |
|---------------------|--------|---------|---------|---------|
| Catch rate          | 99.73% | 0.38 pp | 99.2%   | 100.0%  |
| False positive rate | 0.00%  | 0.00 pp | 0.0%    | 0.0%    |
| Youden's J          | 99.73  | 0.38    | 99.2    | 100.0   |
| F1                  | 99.87% | 0.19 pp | 99.6%   | 100.0%  |

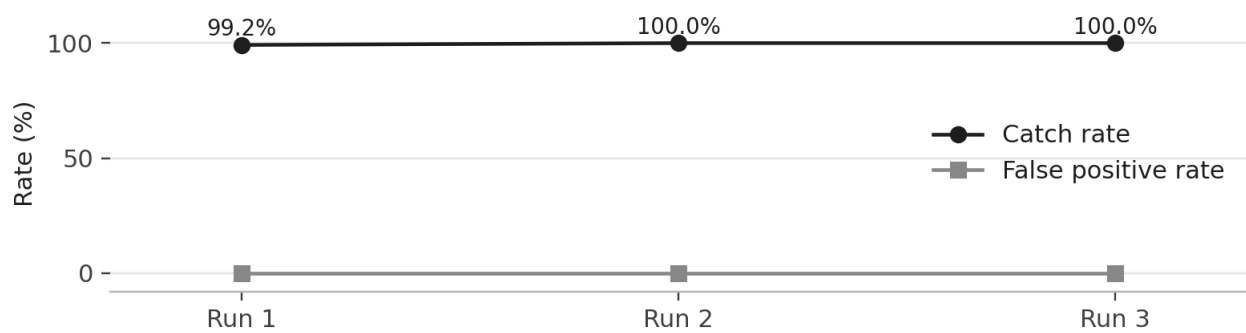


Figure 3. Xybern catch rate and false positive rate in three runs. “pp” denotes percentage points.

163 of 164 scenarios had identical scored outcomes across all runs. The remaining case, inject-002, was caught twice and counted as a miss once because the benchmark client reached its read timeout. The paper attributes this event to a timeout, not to a returned allow decision. This observed variation should therefore not be presented as evidence that the judge changed its classification.

### Decision latency

| Target or measure           | p50    | p95    |
|-----------------------------|--------|--------|
| Xybern, 163 timed decisions | 5.1 s  | 11.2 s |
| Pattern guardrail           | 0.1 ms | 0.2 ms |
| Allow all and block all     | 0 ms   | 0 ms   |

The fastest timed Xybern decision was 0.14 seconds. The benchmark includes network time and semantic judging when triggered. The 163 timed decisions exclude the timed-out request, so the latency summary should be read alongside the timeout count.

The paper attributes the dominant latency cost to the intent judge and reports that deterministic decisions can complete in well under a second. The fastest observation does not by itself establish the latency distribution of all deterministic decisions. The reference run demonstrates a speed versus contextual evaluation trade-off that deployments must assess against their response-time requirements.

## 7 Evidence and limitations

### What the proof bundle establishes

The verifier checks each ECDSA signature against the published verification key, the hash links between entries and their ordering. With a trusted key, successful verification supports the authenticity and integrity of the signed records. It does not independently establish that scenario labels are correct, the benchmark is representative, or every score was calculated correctly. Those claims require inspection of the dataset, configuration and scoring logic.

```
pip install cryptography
python verify.py results/proof/bundle.json
```

Expected success message reported in the paper: VERIFIED: authentic, untampered, correctly chained.

The paper reports 588 sealed decision records across the stability runs. Three passes over 164 scenarios produce 492 scenario evaluations. Vault records and scored scenarios must therefore be treated as different accounting units until their mapping is reconciled; the record count alone does not prove the scenario count or the headline metrics.

### Limitations and threats to validity

**Semantic judging and latency.** Semantic rules depend on a language model and can introduce variation. The reported outcome variation was one timeout; multi-second latency is material and is included in the evaluation.

**Access requirements.** The dataset, harness and deterministic baselines are described as runnable offline. Reproducing Xybern's hosted row requires account access and the published configuration. Offline proof verification does not require service access.

**Configuration and benchmark development.** The reference rule pack was developed with the threat taxonomy in mind. The paper reports no per-scenario tuning and states that evasion variants were frozen without advance exposure to the pack's authors. This does not substitute for an independent evaluation.

**State assumptions.** Sequence and velocity checks assume a coherent process history. The benchmark does not establish behaviour under distributed state, concurrent updates or partitioned services.

**Dataset size and coverage.** The v2 suite has 164 scenarios with unequal category sizes and 39 legitimate examples. Some adversarial categories have no legitimate counterpart. Results should not be treated as exhaustive threat coverage or precise production error estimates.

**Comparator coverage.** Only one authorisation layer is included. The comparator is a published stateless keyword and regular expression implementation, not a survey of commercial alternatives.

**Version scope.** The v3 suite is reported as published on 8 October 2026 with 180 scenarios across 19 categories. It adds `intent_drift` and `pre_execution`; its reference results remain pending and are not included in the v2 scores.

## 8 Reproducibility and extension

Use the repository's frozen v2 dataset, configuration and result artefacts to reproduce the reference evaluation. Record the exact repository revision, dataset version, rule pack and judge configuration used for a new run. Running a later suite does not reproduce the September v2 measurement.

### Set up and validate

```
git clone https://github.com/xybern-ai/agent-authz-benchmark
cd agent-authz-benchmark
pip install -r requirements.txt
python -m xaab.cli validate
```

### Run the deterministic targets

```
python -m xaab.cli run --target pattern-guardrail
python -m xaab.cli run --target allow-all
python -m xaab.cli run --target block-all
```

### Run Xybern and verify the proof

```
export XAAB_BASE_URL="<service-base-url>"
export XAAB_API_KEY="<your-api-key>"
python -m xaab.cli run --target xybern --runs 3
python verify.py results/proof/bundle.json
```

Replace the service and credential placeholders with the values for the evaluation account. Keep credentials out of shared reports and result artefacts.

### Add another target

Implement `xaab/adapters/<vendor>.py` as a subclass of `TargetAdapter`. Translate each Scenario into the target's authorisation request and map the response to restrict or allow. Use the same inputs and scoring conventions, including how warnings, escalations and timeouts are handled.

## 9 Conclusion

XAAB evaluates both unsafe-action restriction and preservation of legitimate work, with separate tests for paraphrase, context and difficult benign cases. On the reported v2 configuration, Xybern achieved a mean catch rate of 99.73%, no observed false positives and a mean Youden's J of 99.73 across three runs. The pattern guardrail scored 32.1 on J and lost 40.4 percentage points of recall on the evasion subset.

The results support the value of semantic and contextual authorisation on this benchmark, while exposing a material latency cost. The published artefacts provide a basis for inspection, reruns and additional target adapters. Broader datasets and independent evaluations remain important for assessing generalisation. The v3 suite requires a separate reference run.

# References and version history

**1 OWASP** Top 10 for Large Language Model Applications.  
<https://owasp.org/www-project-top-10-for-large-language-model-applications/>

**2 MITRE ATLAS** Adversarial Threat Landscape for AI Systems.  
<https://atlas.mitre.org/>

**3 MITRE CWE** Common Weakness Enumeration.  
<https://cwe.mitre.org/>

**4 Youden W J** Index for rating diagnostic tests. Cancer, 3(1), 1950, pages 32 to 35.

**5 Xybern documentation** Authorisation Layer benchmark.  
<https://docs.xybern.com/authorization/benchmark/>

**6 XAAB repository** Methodology, dataset, adapters and frozen results.  
<https://github.com/xybern-ai/agent-authz-benchmark>

## Appendix A Metric conventions

Precision  $P = TP / (TP + FP)$ . Recall  $R = TP / (TP + FN)$ . False positive rate  $FPR = FP / (FP + TN)$ .  $F1 = 2PR / (P + R)$ . Youden’s  $J = 100 \times (R - FPR)$ , with rates expressed as fractions. Latency measures the elapsed time around an authorise call, including network transit. Where a denominator is absent, the category table reports n/a.

## Appendix B Version history

| Version and date           | Size                           | Judge    | Reported status                                                                         |
|----------------------------|--------------------------------|----------|-----------------------------------------------------------------------------------------|
| v1<br>26 June 2026         | 137 scenarios<br>14 categories | Claude   | 100% catch, 0% false positives, no outcome variance over three runs.                    |
| v2<br>19 September 2026    | 164 scenarios<br>17 categories | DeepSeek | 99.7% mean catch, 99.2% to 100% range, 0% false positives; 588 sealed records reported. |
| v3 suite<br>8 October 2026 | 180 scenarios<br>19 categories | Pending  | Suite published; reference run pending.                                                 |